

Information Security

Unit- 1

Overview of Computer Security

Computer Security Concept

- NIST (National Institute of Standard Technology) defines the term computer security as follows:

“The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications)”

- This definition introduces three key objectives that are at the heart of computer security:

1. Confidentiality
2. Integrity
3. Availability

Computer Security Concept

1. Confidentiality:

- The information cannot be understood by anyone for whom it was unintended.
- This term covers two related concepts:
 - a) **Data confidentiality:** Assures that private or confidential information is not made available or disclosed to unauthorized individuals.
 - b) **Privacy:** Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

Computer Security Concept

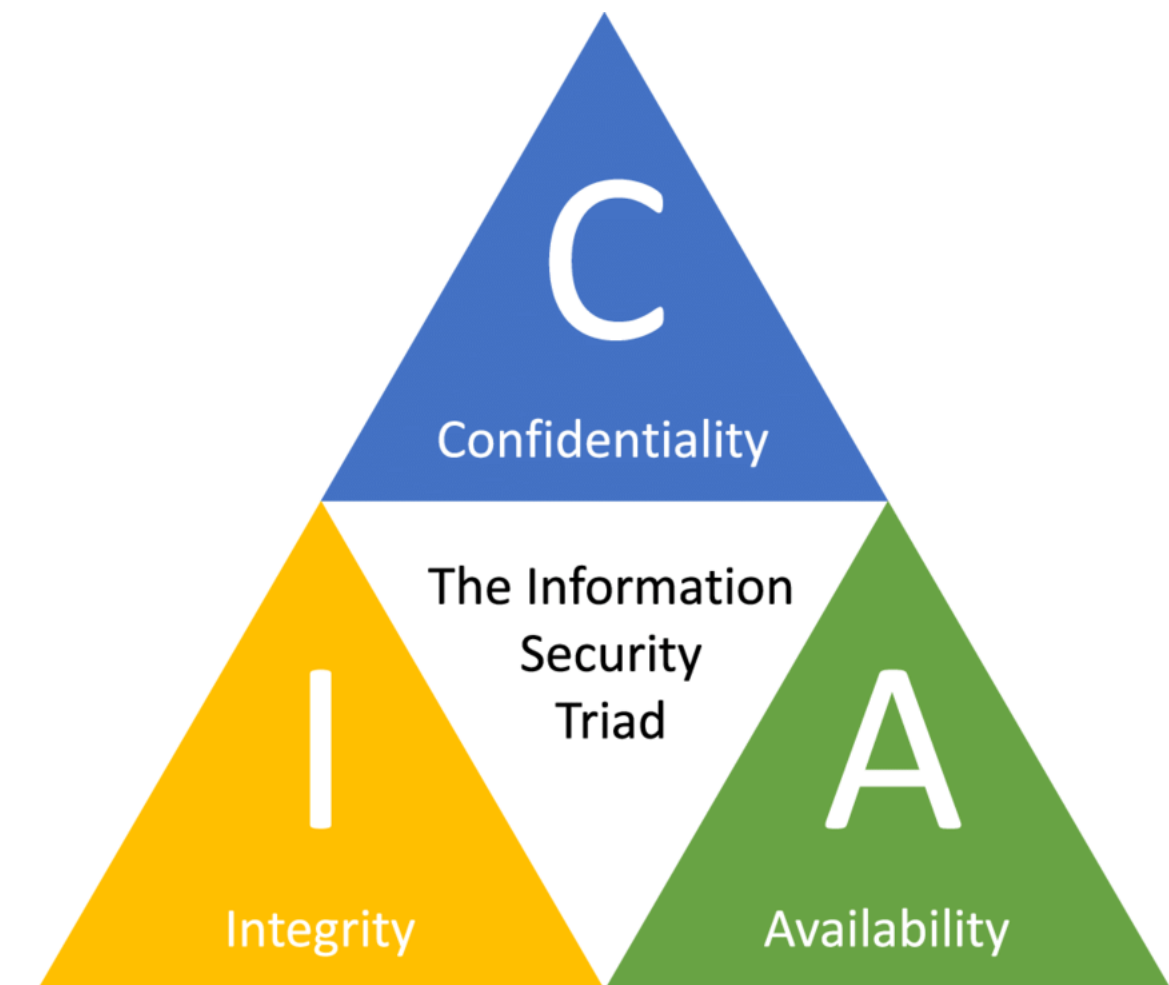
2. Integrity :

- This objective is concerned with maintaining the accuracy, consistency, and trustworthiness of data and systems.
- It involves two main aspects:
 - a) **Data Integrity:** Ensures that information remains unchanged and uncorrupted during storage, processing, or transmission. Any alterations to data should occur only through authorized means, preventing unauthorized modifications or tampering.
 - b) **System Integrity:** Guarantees that a system functions as intended without unauthorized interference or manipulation. It ensures that the system's components, including hardware, software, and firmware, operate in a secure and reliable manner, free from deliberate unauthorized actions.

Computer Security Concept

3. Availability:

- This objective focuses on ensuring that computer systems and services are accessible and usable by authorized users when needed. It aims to prevent disruptions or denial of service that could prevent legitimate users' ability to access resources or perform tasks.
- By addressing these objectives—confidentiality, integrity, and availability—organizations can establish a comprehensive approach to computer security, safeguarding their information systems and resources from various threats and vulnerabilities.
- These three concepts form what is often referred to as the CIA triad. The three concepts embody the fundamental security objectives for both data and for information and computing services.



Computer Security

- Computer security is the act of protection of computer systems and keep critical information from unauthorized access, theft of misuse.
- Hardware is secured the same way as any sensitive equipments, but system access and authorization are protected through various protocol.
- This include admin restriction to normal users, external devices such as pen drives, flash drives should be disabled by the admin.

Information Security

- It is the act of protecting the information by mitigating the information risks.
- It involves the protection of information system, information processed, stored and transmitted by the system from unauthorized access, use , disruption, modification and destruction.

Network Security

- It is the act of protecting network and data from different kind of breaches, intrusion and other threats.
- It involves access control, virus and anti virus software, application security, network analytics, firewall, VPN, encryption and more.

Security Threats:

- It is possible security violation that might exploit the vulnerability of a system or assets.
- It may or may not be malicious.
- It can be initiated by the system itself as well as outsider.
- It is comparatively hard to detect.
- Table below, describes four kinds of threat consequences and lists the kinds of attacks that result in each consequence, based on RFC 4949 standard.

Security Threats:

Threat Consequence	Threat Action (Attack)
Unauthorized Disclosure A circumstance or event whereby an entity gains access to data for which the entity is not authorized.	Exposure: Sensitive data are directly released to an unauthorized entity. Interception: An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. Inference: A threat action whereby an unauthorized entity indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from characteristics or by-products of communications. Intrusion: An unauthorized entity gains access to sensitive data by circumventing a system's security protections.
Deception A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.	Masquerade: An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity. Falsification: False data deceive an authorized entity. Repudiation: An entity deceives another by falsely denying responsibility for an act.
Disruption A circumstance or event that interrupts or prevents the correct operation of system services and functions.	Incapacitation: Prevents or interrupts system operation by disabling a system component. Corruption: Undesirably alters system operation by adversely modifying system functions or data. Obstruction: A threat action that interrupts delivery of system services by hindering system operation.
Usurpation A circumstance or event that results in control of system services or functions by an unauthorized entity.	Misappropriation: An entity assumes unauthorized logical or physical control of a system resource. Misuse: Causes a system component to perform a function or service that is detrimental to system security.

Assets:

- The assets of a computer system can be categorized as hardware, software, data, and communication lines and networks.
- These four categories and their impact on CIA is shown in table below:

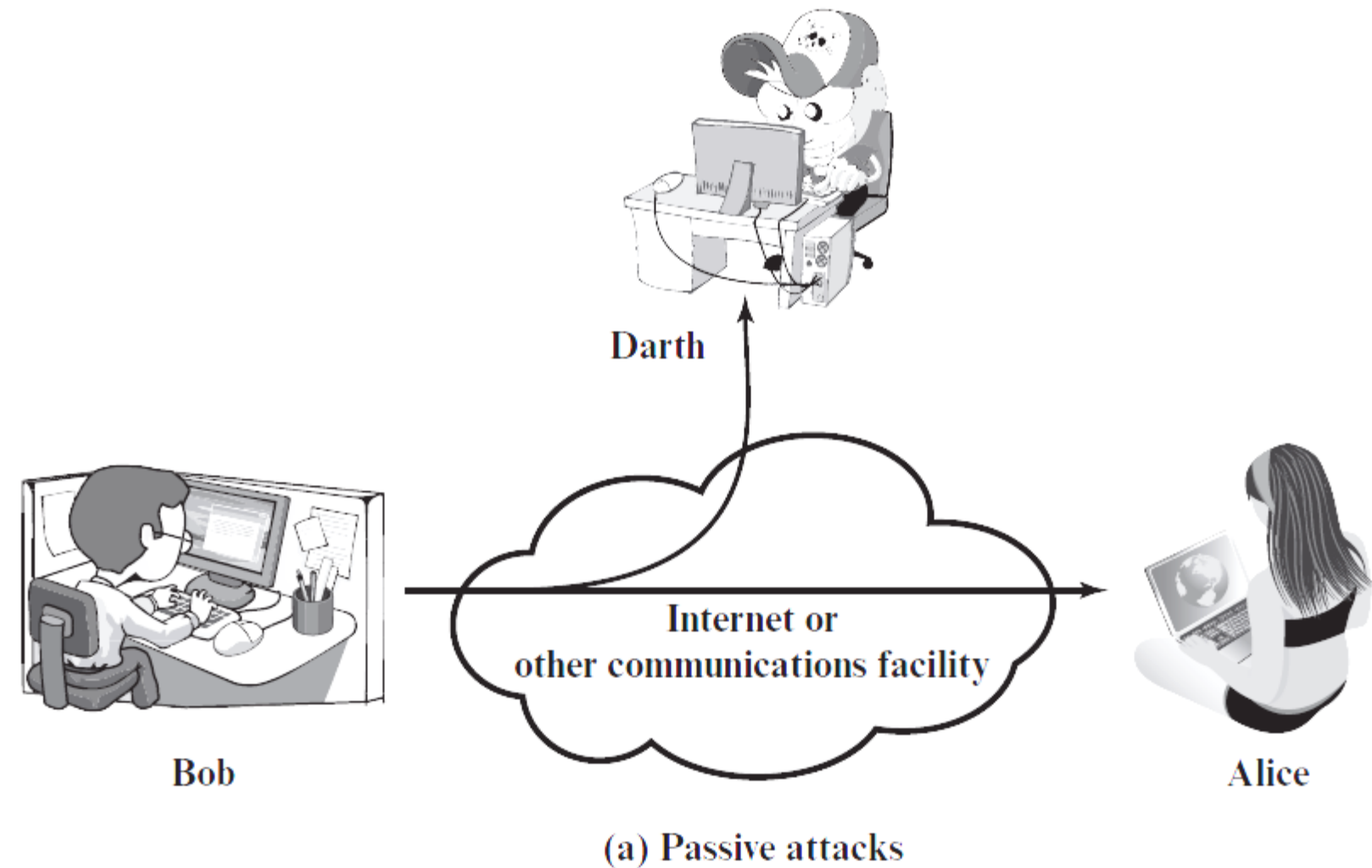
	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.	An unencrypted USB drive is stolen.	
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Security Attacks:

- The major goals of security i.e. Confidentiality, Integrity and Availability can be threatened by security attacks.
- Security attack is an intelligent act that is deliberate attempt to evade the security services and violate the security policy of a system.
- There are basically two types of attack-
 1. Passive attack
 2. Active attack

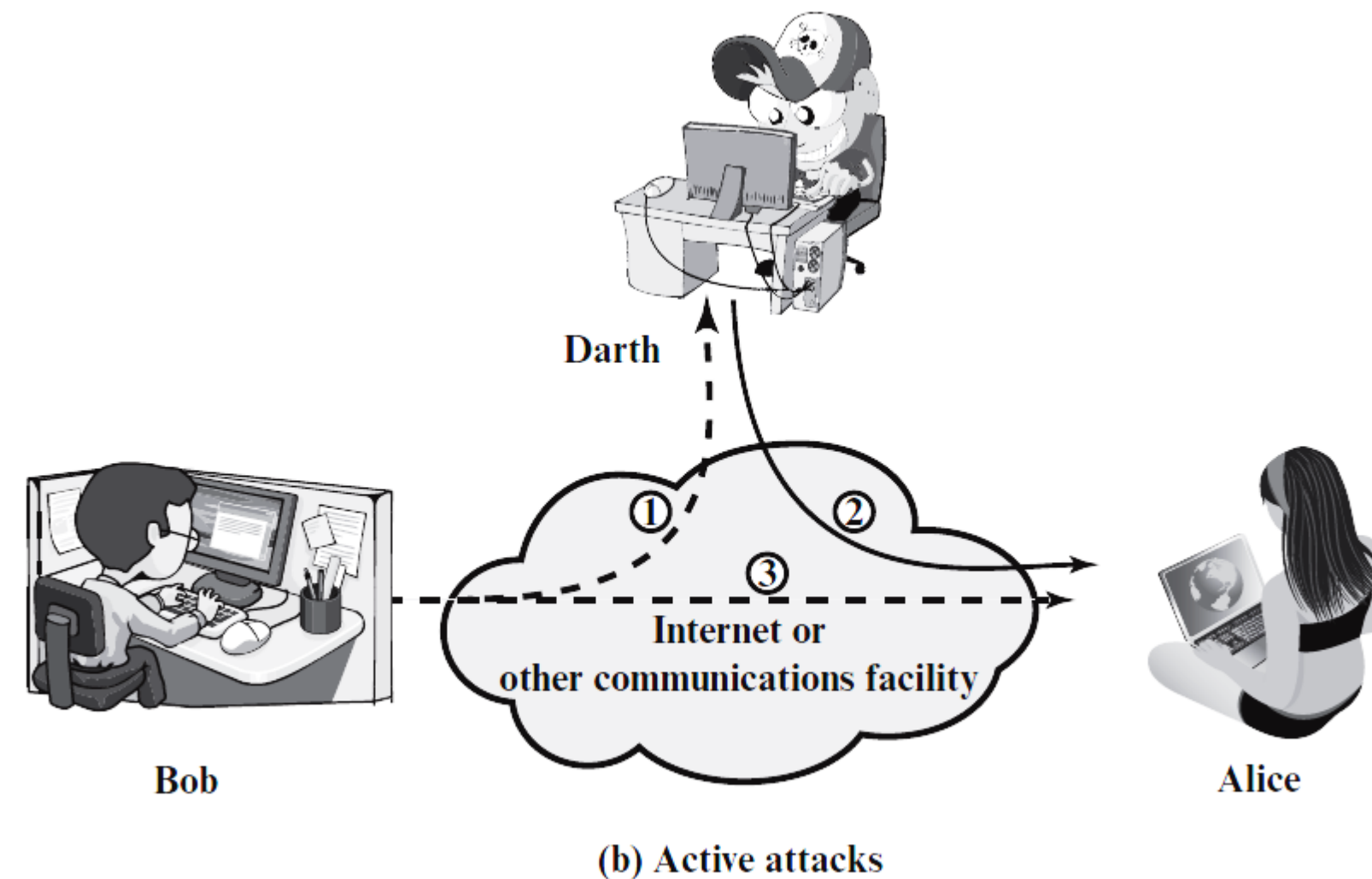
1. Passive Attack:

- A passive attack attempts to learn or make use of information from the system but does not affect system resources. Passive attacks are in the nature of eavesdropping on or monitoring transmission.
- Here the goal of the opponent is to obtain information that is being transmitted.
- Types of passive attacks are -
 1. Release of message contents
 2. Traffic analysis etc.

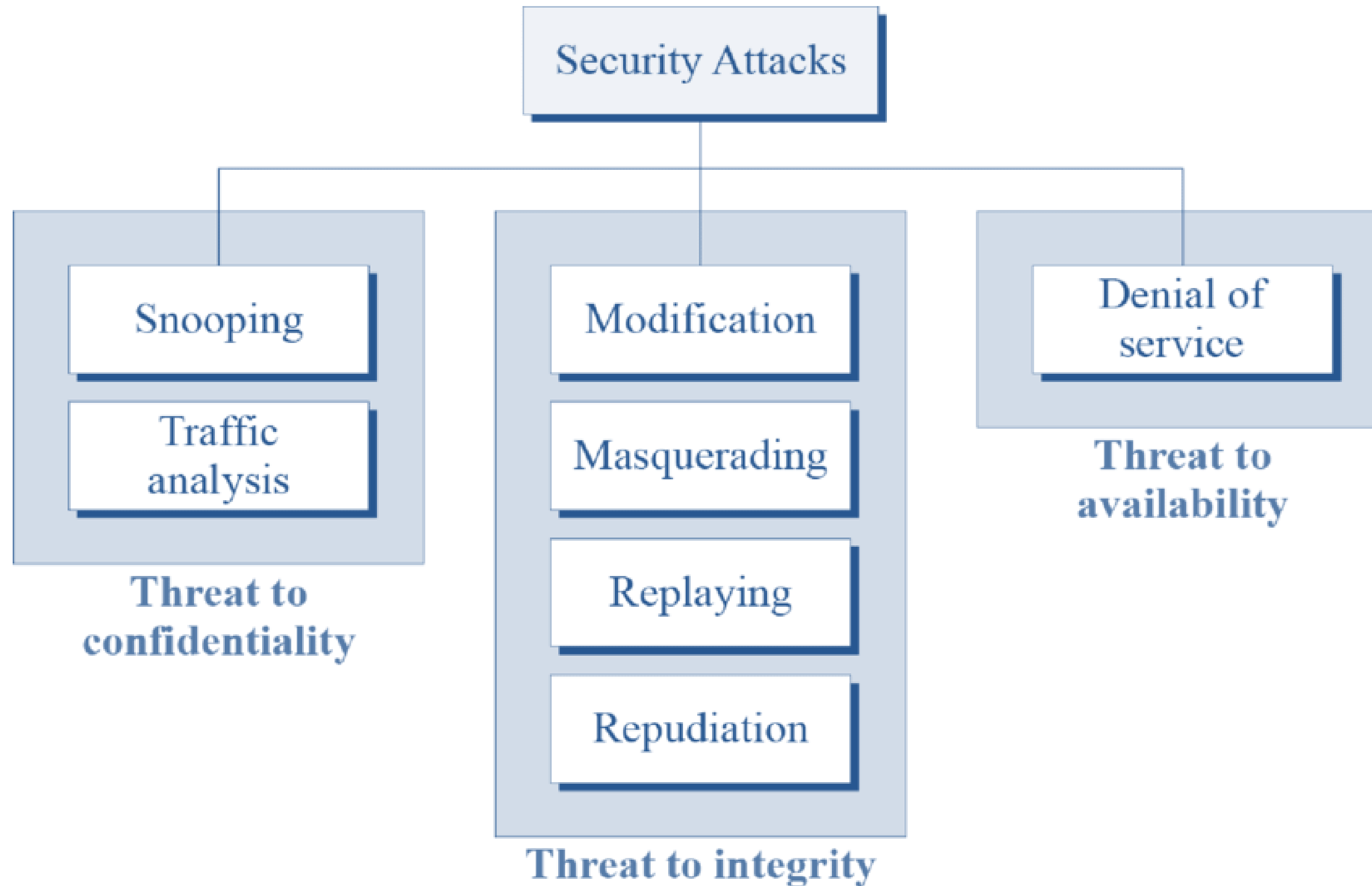


2. Active Attack:

- An active attack attempts to alter system resources or affect their operations.
- Active attacks involve some modification of the data stream or the creation of false statements.
- Some active attacks are as follows-
 1. Masquerade
 2. Modification of message
 3. Repudiation
 4. Replay
 5. Denial of Service etc.



Classification of Security Attack Based on Security Goals



1. Attacks Threatening Confidentiality :

- Attacks threatening the confidentiality of information are as follows-

a) Snooping :

- Snooping defines the unauthorized access of data.
- It can avoid snooping, data is create non-intelligible to the unauthorized entities by using encryption technique.

b) Traffic Analysis :

- Although through encryption, data is create non-intelligible, an unauthorized user can try to acquire some other type of data by monitoring the online traffic of the network.

2. Attacks Threatening Integrity :

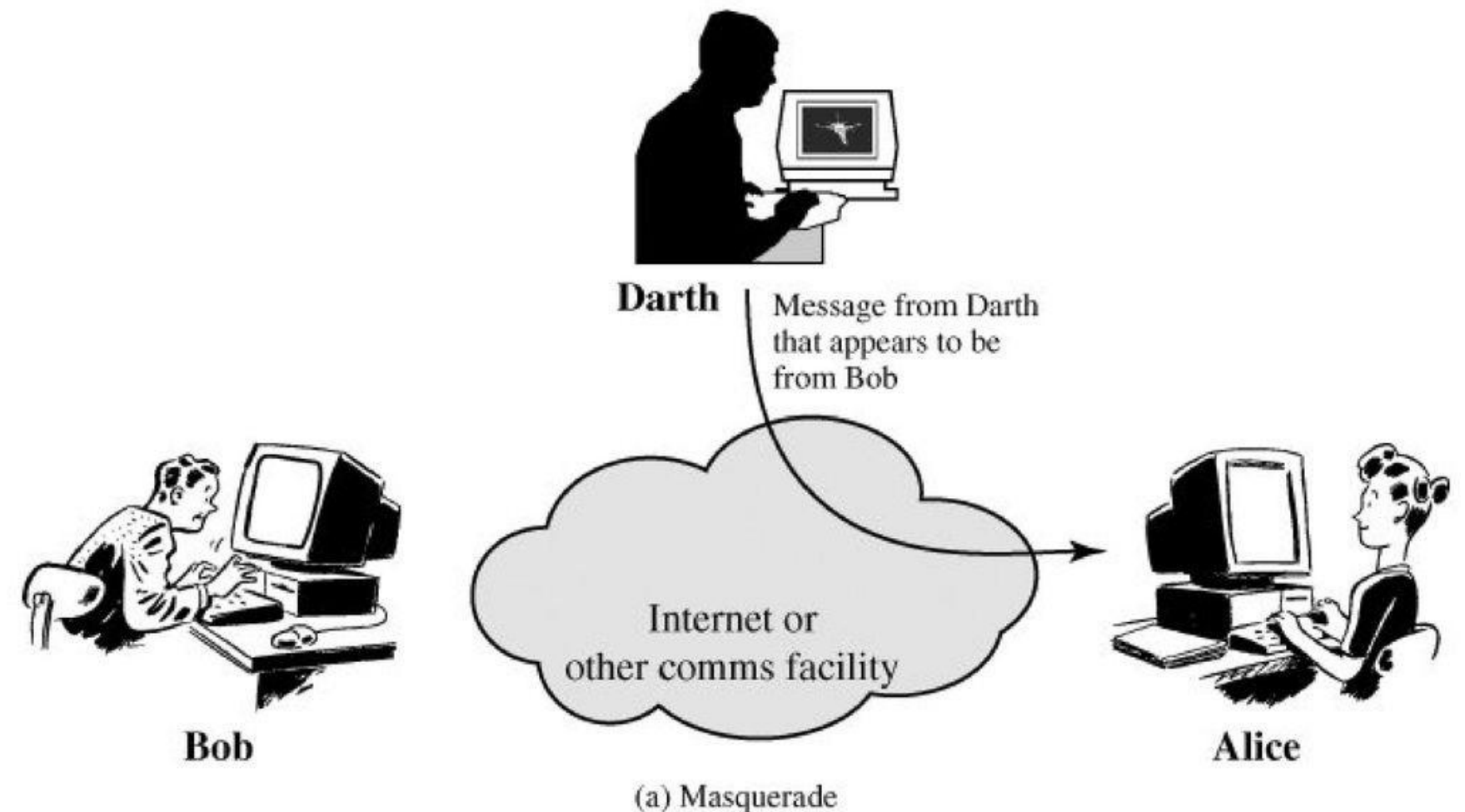
- Attacks threatening the integrity of information are as follows-

a) Modification :

- After accessing information, the attacker modifies the data to create it beneficial to himself.

b) Masquerading :

- Masquerading or spoofing appears when one entity pretends to be a different entity.



2. Attacks Threatening Integrity :

c) Replaying :

- In replaying, attacker access a copy of the message sent by a user and next transmits it to create an unauthorized effect.

d) Repudiation :

- This attack is implemented by one of the two parties in the communication. The sender of the message can deny that it has sent the message or the receiver of the message can later deny that it has received the message.

3. Attacks Threatening Availability:

- Attacks threatening availability of information is DOS attack.

Denial of Service Attack:

- This attack can slow down or absolutely interrupt the service of the system.
- For example, a DOS attacker can send too many requests to a server and the server crashes due to heavy load.

Security Requirements:

- There are a number of ways of classifying and characterizing the countermeasures that may be used to reduce vulnerabilities and deal with threats to system assets.
- Here are few countermeasures in terms of functional requirements, defined in FIPS 200 (Minimum Security Requirements for Federal Information and Information Systems).
- This standard enumerates 17 security related areas with regard to protecting the confidentiality, integrity, and availability of information systems and the information processed, stored, and transmitted by those systems.

Security Requirements:

S.N	Security Control	Description			
1	Access Control	Only authorized users can access systems and perform permitted actions	11	Physical & Environmental Protection	Physical access to systems is limited and environments are monitored
2	Awareness & Training	Users and managers are trained about security risks and policies	12	Planning	Security plans are developed and updated for system protection
3	Audit & Accountability	System activities are recorded and tracked for accountability	13	Personnel Security	Individuals are screened and managed to ensure they meet security standards
4	Certification, Accreditation & Security Assessment	Security controls are regularly checked and improved	14	Risk Assessment	Risks to operations and assets are periodically assessed
5	Configuration Management	System configurations are securely maintained and managed	15	System & Services Acquisition	Security is integrated into the purchase and development of systems
6	Contingency Planning	Backup and recovery plans are prepared for emergencies	16	System & Communications Protection	Information transmitted or received by the system is monitored and controlled
7	Identification & Authentication	User identity is verified before granting access	17	System & Information Integrity	Information and systems are protected from unauthorized changes and malware
8	Incident Response	Security incidents are detected, handled, and reported			
9	Maintenance	System maintenance is performed regularly and securely			
10	Media Protection	Physical and digital media are protected and sanitized			

Security Design Principles

➤ The National Centers of Academic Excellence [NCAE13] in Information Assurance/Cyber Defense, list the following as fundamental security design principles-

1. Economy of mechanism
2. Fail-safe defaults
3. Complete mediation
4. Open design
5. Separation of privilege
6. Least privilege
7. Least common mechanism
8. Psychological acceptability
9. Isolation
10. Encapsulation
11. Modularity
12. Layering
13. Least astonishment

Security Design Principles

Principle	Simple Meaning	Encapsulation	Hide internal details, expose only necessary parts
Economy of Mechanism	Keep the system simple so it is easier to secure	Modularity	Divide system into small independent parts
Fail-safe Defaults	By default, deny access unless allowed	Layering	Use multiple layers of security
Complete Mediation	Check permission every time a user accesses data	Least Astonishment	System should behave as users expect (no surprises)
Open Design	Security should not depend on secret design		
Separation of Privilege	Require multiple conditions/permissions for access		
Least Privilege	Give users only minimum access needed		
Least Common Mechanism	Avoid sharing resources to reduce risk		
Psychological Acceptability	Security should be easy and user-friendly		
Isolation	Separate processes/users to prevent interference		

Attack Surface and Attack Trees

Attack Surface:

- Attack surfaces refer to all the points in a system where an attacker can try to breach security.
- These are the vulnerable areas that can be exploited to gain unauthorized access or cause damage.
- Examples of attack surfaces include:
 1. **Open Ports:** These are points where data enters or leaves a system, like the ports on a web server.
 2. **Internal Services:** Services that are accessible within a network but not meant to be exposed to the outside world.
 3. **Code Processing Data:** Any code that handles incoming data, such as emails or documents.
 4. **User Interfaces:** Interfaces like web forms or SQL databases that interact with users.
 5. **Human Element:** Employees who might be tricked into giving away sensitive information (social engineering).

Type of Attack Surface:

➤ Attack surfaces can be categorized into three types:

1. Network Attack Surface:

Vulnerabilities found in network protocols, which can be exploited for attacks like denial-of-service or disrupting communications.

2. Software Attack Surface:

Vulnerabilities in the code of applications, utilities, or operating systems, especially web server software.

3. Human Attack Surface:

Vulnerabilities involving human errors, social engineering, or insider threats.

Attack Trees :

- Attack trees are a way to visualize and organize potential attacks on a system. They help in understanding how an attacker might exploit vulnerabilities to achieve a specific goal.
- An attack tree starts with a root node representing the main goal of the attacker, such as compromising a user's account. From this root, branches extend to sub-goals or specific attack steps.
- Each node in the tree can be an AND-node or an OR-node.
 - **AND-node:** All sub-goals must be achieved to reach the main goal.
 - **OR-node:** Achieving any one of the sub-goals is enough to reach the main goal.
- These are the final nodes and represent specific methods to initiate an attack.

Example: Internet Banking Authentication :

- Consider an attack tree for an Internet banking authentication system. The main goal is to compromise a user's account. Here are some strategies an attacker might use, represented as branches of the tree:

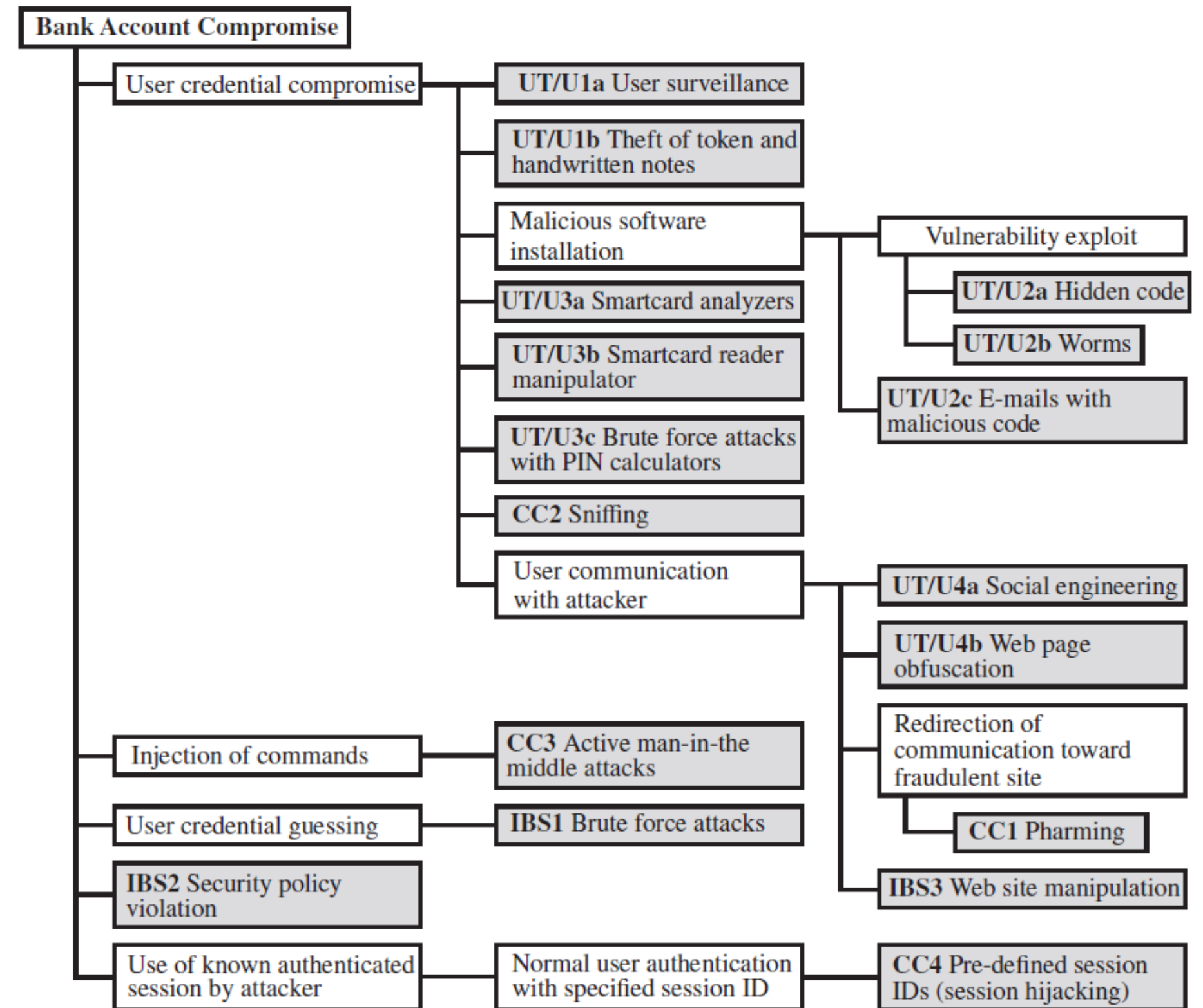


Figure 1.5 An Attack Tree for Internet Banking Authentication

Security Services and Mechanisms:

- Indeed, the International Telecommunication Union Telecommunication Standardization Sector (ITU-T) provides standards and recommendations for various aspects of information and communication technologies (ICT), including security. These standards often outline security services and mechanisms to help organizations establish robust security practices. Here are the ITU-T security services and mechanisms:

1. Security Services

- A service that enhance the security of the data processing systems and information transfers of an organization.
- The services are intended to counter security attacks and they make use of one or more security mechanisms to provide the service.
- Based on X.800, classification of security services are as follows-

1. Data Confidentiality :

1. Connection confidentiality
2. Connection less confidentiality
3. Selective field confidentiality
4. Traffic flow confidentiality

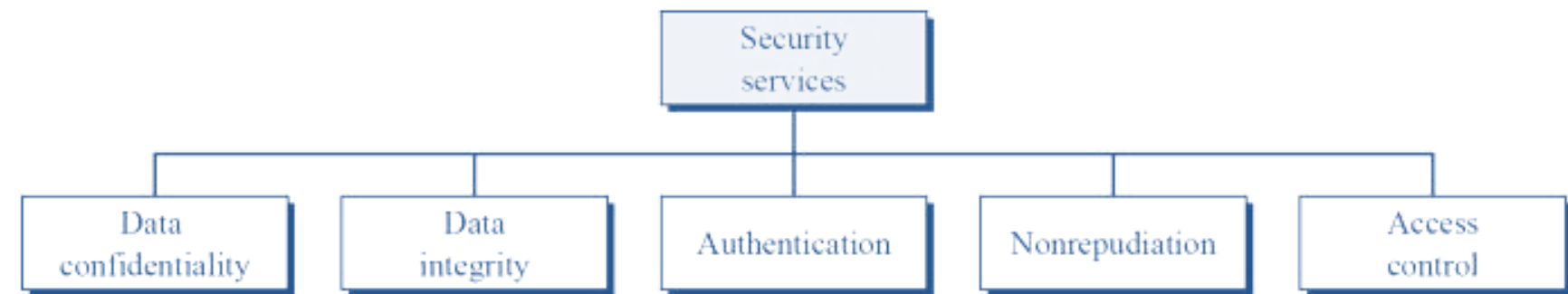


Figure . Security services

2. Data Integrity :

1. Connectionless integrity
2. Connection integrity with recovery
3. Connection integrity with out recovery
4. Selective – field connection integrity
5. Selective-field connectionless integrity

3. Authentication :

1. Peer entity authentication
2. Data origin authentication

4. Non-Repudiation :

1. Non-repudiation origin
2. Non-repudiation destination

5. Access Control :

1. Access control

2. Security Mechanisms

- According to X.800, the security mechanisms are divided into those implemented in a specific protocol layer and those that are not specific to any particular protocol layer.

1. Specific Security Mechanisms:

- Incorporated into the appropriate protocol layer in order to provide some of the OSI security services.
 1. Encipherment
 2. Digital signature
 3. Access control
 4. Data integrity
 5. Authentication exchange
 6. Traffic padding
 7. Routing control
 8. Notarization

2. Pervasive Security Mechanisms:

➤ These are not specific to any particular OSI security service or protocol layer.

1. Trusted functionality
2. Security level
3. Event detection
4. Security audit trail
5. Security recovery

Security Policy

- A security policy is a set of rules and guidelines designed to protect the valuable and sensitive parts of a computer system or an organization. It outlines how to safeguard important resources from potential threats.
- More usefully, a security policy is a formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources (RFC 4949).
- In developing a security policy, a security manager needs to consider the following factors:
 1. The value of the assets being protected
 2. The vulnerabilities of the system
 3. Potential threats and the likelihood of attacks

Trade-offs For a Security Policy

1. **Ease of Use vs. Security:** More security usually means less convenience. For example:
 - **Access Controls:** Users might need to remember passwords and go through extra steps to access the system.
 - **Network Security:** Measures like firewalls can slow down internet speed.
 - **Virus Checking:** Scanning for viruses can use up processing power and sometimes cause system issues.

2. **Cost of Security vs. Cost of Failure:** Implementing security measures can be expensive and might slow down operations. However, the cost of not having enough security can be even higher if a security breach occurs. This includes:
 - **Direct Costs:** Money spent on security tools and their maintenance.
 - **Indirect Costs:** Potential losses from security breaches, such as data loss, downtime, and damage to reputation.

Security Implementation

- Security implementation involves taking steps to protect a system from attacks and manage them if they occur. It includes four main strategies:

1. Prevention:

- **Goal:** Stop attacks before they happen.
- **Example:** Encrypting data to prevent unauthorized access. Using strong encryption algorithms and securing encryption keys can ensure that transmitted data remains confidential and protected from interception.

2. Detection:

- **Goal:** Identify attacks that cannot be completely prevented.
- **Example:** Intrusion detection systems monitor for unauthorized access. Systems can also detect denial-of-service attacks, where resources are overwhelmed and legitimate users are blocked from accessing services.

3. Response :

- **Goal:** Take action when an attack is detected to stop it and minimize damage.
- **Example:** If an intrusion or denial-of-service attack is detected, the system can take steps to halt the attack, such as blocking malicious IP addresses or shutting down affected services temporarily.

4. Recovery :

- **Goal:** Restore normal operations after an attack.
- **Example:** Using backup systems to restore data integrity. If data is compromised, having a backup allows the system to reload a previous, uncorrupted version of the data.

Important Questions

1. What is meant by the CIA triad?
2. What is the difference between data integrity and system integrity?
3. List and briefly define the kinds of threat consequences and the types of threat actions which cause these consequences.
4. List and briefly define the fundamental security design principles.
5. What is a security policy? What are the actions involved when implementing a security policy?
6. Differentiate between a network attack surface and a software attack surface.
7. What is the difference between active attack and passive attack.

!!!Thank you!!!